

Repair Request API Contract

REST Contract + Bounded Query / Cancellation Performance Rules

Document Control	Value
Document ID	RR-API-001
Version	1.2 - Performance Revision Candidate
Status	Ready for Technical Baseline Approval
Revision Date	12 September 2026
Supersedes	RR-API-001 v1.1
Revision Scope	Add bounded query, cancellation, report/file and evidence contracts without changing endpoints, actors or business semantics.
Approval	Business Owner / Project Manager + Architecture/QA review - pending

Revision rule / กติกาการแก้ไข: เอกสารฉบับนี้เป็นการปิด Audit ด้าน Performance/Technical Design เท่านั้น ไม่เปลี่ยน State, Role, Guard, SLA, Permission, Notification Recipient หรือ Business Semantics ที่ล็อกไว้เดิม หากคำตัดสินด้าน Performance ใดไม่มีอยู่ใน Business Baseline จะระบุเป็น **Gap / Proposed Technical Decision / Pending Approval** และไม่ถือเป็น Requirement เดิมโดยอัตโนมัติ.

Document control note: หน้านี้เป็น Document Control ที่มีผลสำหรับ revision นี้และ supersede ค่า Version/Status บนหน้าปกของ source baseline ที่ถูกรักษาไว้ในหน้าถัดไปเพื่อ traceability.

Repair Request API Contract

REST API Contract / MVP Technical Design Revision

Document Control	Value
Document ID	RR-API-001
Version	1.1 - Technical Design Baseline Candidate
Status	Ready for Technical Baseline Approval
Revision Date	12 September 2026
Approval	Business Owner / Project Manager - formal name/signature pending
Sources	Requirement v1.5; BR v1.5; State v1.5; UC v1.6; DD v1.3; ERD v1.1; DB v1.1
Audience	API Architect, Backend Developer, Frontend Developer, QA, Security Reviewer
Language	ภาษาไทยเป็นหลัก พร้อมชื่อ Entity / Role / State / API เป็นภาษาอังกฤษ
Purpose	กำหนด REST endpoints, DTO/headers/errors, authorization, state guards, concurrency, idempotency, notifications and traceability.

Revision rule: เอกสารฉบับนี้ปิด Audit findings ของชุดวันที่ 11 September 2026 โดยแยกสิ่งที่เป็น Business Baseline ออกจาก Technical Design อย่างชัดเจน. การลงนามอนุมัติจริงยังเป็นหน้าที่ของ Business Owner / Project Manager.

1. API Design Principles

Area	Contract
Base path	/api/v1; HTTPS only deployed environments; JSON; multipart/form-data for upload.
Authentication	Authenticated principal required; exact token mechanism is architecture choice. Client tenant_id/actor_id/role are never authority.
Authorization	Backend validates permission, tenant/site, ownership/assignment, current state/guard for every action.
State mutation	No generic status update endpoint. Explicit action endpoints only.
Concurrency	State-changing/update commands require If-Match current ETag/rowversion; stale -> 409 no partial transition.
Idempotency	Critical create/transition actions reject duplicate/stale execution; DB uniqueness + current state protect conversion/acceptance.
Audit	Significant action writes entity/id/action/actor/time/from/to/reason/old/new/correlation.
Notification	Outbox event + recipients after business commit; send failure never rolls back state.
Time	ISO-8601 UTC; UI uses Site timezone.
Files	Private binary; allowed type/size; CLEAN required for mandatory evidence.

2. Common Headers / Error Contract

Header	Required	Purpose
Authorization	Yes	Authenticated principal
X-Correlation-ID	Recommended	Caller UUID or server-generated; links audit/outbox/logs
If-Match	State-changing/update	Current ETag/rowversion token
ETag	Mutable response	Current token
Content-Type	Yes	application/json or multipart/form-data

HTTP	Code	Meaning
400	BAD_REQUEST	Malformed request
401	UNAUTHENTICATED	No valid principal
403/404	ACCESS_DENIED / NOT_FOUND	Non-leaking scope/authorization behavior
409	STATE_CONFLICT / CONCURRENCY_CONFLICT	Illegal state or stale token; no partial write
422	VALIDATION_FAILED	Field/master/business validation
500	INTERNAL_ERROR	Correlation ID returned; no sensitive detail

3. Endpoint Catalog

ID	Method	Path	Purpose	Actor	Concurrency
RR-API-001	POST	/api/v1/repair-requests	Create Draft	Requester	-
RR-API-002	PATCH	/api/v1/repair-requests/{id}	Edit own Draft	Requester	If-Match
RR-API-003	GET	/api/v1/repair-requests	List/Search Requests	Authorized	-
RR-API-004	GET	/api/v1/repair-requests/{id}	Request detail	Authorized	-
RR-API-005	POST	/api/v1/repair-requests/{id}/submit	Submit + duplicate + SLA start	Requester	If-Match
RR-API-006	POST	/api/v1/repair-requests/{id}/approve	Approve	Approver	If-Match
RR-API-007	POST	/api/v1/repair-requests/{id}/reject	Reject(reason)	Approver	If-Match
RR-API-008	POST	/api/v1/repair-requests/{id}/return-for-correction	Return to DRAFT	Approver	If-Match
RR-API-009	POST	/api/v1/repair-requests/{id}/cancel	Cancel Request	Requester	If-Match
RR-API-010	POST	/api/v1/repair-requests/{id}/convert-to-work-order	Convert atomically	Coordinator	If-Match
WO-API-001	GET	/api/v1/work-orders/{id}	WO detail	Authorized	-
WO-API-002	POST	/api/v1/work-orders/{id}/schedule	Schedule Visit	Coordinator	If-Match
WO-API-003	POST	/api/v1/service-visits/{id}/reassign	Reassign	Coordinator	If-Match
WO-API-004	POST	/api/v1/service-visits/{id}/reschedule	Reschedule	Coordinator	If-Match
WO-API-005	POST	/api/v1/service-visits/{id}/cancel	Cancel Visit	Coordinator	If-Match
WO-API-006	POST	/api/v1/service-visits/{id}/mark-missed	Mark MISSED	Coordinator	If-Match
WO-API-007	POST	/api/v1/service-visits/{id}/missed-decision	Decide MISSED / optionally new Visit	Coordinator	If-Match
WS-API-001	POST	/api/v1/service-visits/{id}/check-in	Check-in	Assigned Technician	If-Match
WS-API-002	POST	/api/v1/work-sessions/{id}/pause	Pause	Assigned Technician	If-Match
WS-API-003	POST	/api/v1/work-sessions/{id}/resume	Resume	Assigned Technician	If-Match
WS-API-004	POST	/api/v1/work-sessions/{id}/check-out	Check-out	Assigned Technician	If-Match
WO-API-008	POST	/api/v1/work-orders/{id}/submit-work-summary	Submit summary	Team Lead	If-Match
WO-API-009	POST	/api/v1/work-orders/{id}/submit-for-acceptance	Supervisor review -> acceptance	Supervisor	If-Match
ACC-API-001	POST	/api/v1/work-orders/{id}/accept	Customer Accept	Designated Contact	If-Match
ACC-API-002	POST	/api/v1/work-orders/{id}/reject	Customer Reject	Designated Contact	If-Match
CA-API-001	POST	/api/v1/corrective-actions/{id}/submit-plan	Submit plan	Team Lead	If-Match
CA-API-002	POST	/api/v1/corrective-actions/{id}/approve-plan	Approve plan	Supervisor	If-Match
CA-API-003	POST	/api/v1/corrective-actions/{id}/schedule-rework	Create corrective Visit	Coordinator/Supervisor authorized	If-Match
CST-API-001	PUT	/api/v1/work-orders/{id}/cost-summary	Create/update Cost	Team Lead	If-Match
CST-API-002	POST	/api/v1/work-orders/{id}/review-cost-summary	Review Cost	Supervisor	If-Match

ID	Method	Path	Purpose	Actor	Concurrency
WO-API-010	POST	/api/v1/work-orders/{id}/close	Close	Supervisor	If-Match
WO-API-011	POST	/api/v1/work-orders/{id}/cancel	Cancel WO	Supervisor	If-Match
TIME-API-001	POST	/api/v1/work-sessions/{id}/time-corrections	Request correction	Technician/Team Lead	-
TIME-API-002	POST	/api/v1/time-corrections/{id}/approve	Approve correction	Supervisor	If-Match
TIME-API-003	POST	/api/v1/time-corrections/{id}/reject	Reject correction	Supervisor	If-Match
SLA-API-001	GET	/api/v1/sla-records/{repairRequestId}	SLA status/history	Authorized	-
SLA-API-002	POST	/api/v1/sla-records/{id}/override	Override effective due	Supervisor with permission	If-Match
AUD-API-001	GET	/api/v1/entities/{entityType}/{entityId}/timeline	Timeline	Authorized	-
REP-API-001	GET	/api/v1/reports/repair-requests	MVP reports	Authorized reporting role	-
FILE-API-001	POST	/api/v1/repair-requests/{id}/attachments	Upload attachment	Authorized owner	-
FILE-API-002	GET	/api/v1/files/{fileAssetId}	Authorized download	Authorized	-
NTF-API-001	GET	/api/v1/me/notifications	In-app notification inbox	Authenticated	-
NTF-API-002	POST	/api/v1/me/notifications/{id}/read	Mark own notification read	Authenticated recipient	-

4. Key Request Contracts

```

POST /api/v1/repair-requests
{
  "siteId":"uuid", "equipmentId":"uuid|null", "locationId":"uuid|null",
  "requestCategoryId":"string", "description":"string", "priorityCode":"string",
  "requestContactId":"uuid", "preferredStartAt":"UTC", "preferredEndAt":"UTC"
}
// Requester and Customer/Company are NOT accepted as authority fields:
// Requester = authenticated principal; Customer/Company scope = server-derived tenant_id.

POST /api/v1/repair-requests/{id}/submit
{ "duplicateContinuationReason":"string|null" }

POST /api/v1/service-visits/{id}/missed-decision
{ "decision":"RESCHEDULE|FOLLOW_UP|REASSIGN|NO_FOLLOW_UP", "reason":"required",
  "newSchedule": { ... required only when a new Visit is created ... } }

POST /api/v1/sla-records/{id}/override
{ "newEffectiveDueAt":"UTC", "reason":"required" }
// Response includes originalDueAt, effectiveDueAt, riskAt (= effectiveDueAt - 4h), breachedAt, stoppedAt.

```

5. Security / Concurrency / Atomicity

Control	API Requirement
Tenant isolation	Resolve tenant from authenticated principal and scope every query/action.
Site/ownership	Validate site scope, owner/team assignment and role per use case.
IDOR	Guessed out-of-scope IDs return non-leaking 403/404 and security correlation.

Control	API Requirement
PII	Acceptance contact/file data Restricted; avoid sensitive values in logs/errors.
Concurrency	If-Match on aggregate-changing actions; stale 409.
Atomicity	Convert, Accept/Reject, Corrective creation, WO cancel, Close, Time Correction approval, SLA Override use DB transaction boundaries.
Notification	Delivery retry independent; no reversal of committed state.

6. DTO / State Contract

DTO	Key Fields
RepairRequestSummary	repairRequestId, requestNo, status, siteId, category, priority, submittedAt, sla summary, rowVersion
WorkOrderSummary	workOrderId, workOrderNo, repairRequestId, status, ownerTeamId, teamLeadId, sla summary, rowVersion
ServiceVisitDto	serviceVisitId, workOrderId, visitType, status, assignment, schedule, sourceMissedVisitId, missedDecisionCode, rowVersion
SlaDto	slaRecordId, startedAt, originalDueAt, effectiveDueAt, riskAt, riskNotifiedAt, breachedAt, stoppedAt, stopReason, overrides[]
NotificationDto	notificationId, eventCode, entityType/id, createdAt, readAt, deliveryStatus; only current recipient

7. Search / Pagination / Reporting / Files

List/report APIs apply tenant/site scope server-side. page/pageSize/sort are technical conventions; exact max page size is deployment config. Export uses the same scope/PII rules. Files never return public storage URLs.

8. Readiness

API Contract v1.1 is aligned to revised baseline IDs and closes Customer mapping, MISSED decision, SLA Risk and notification routing gaps. Ready for OpenAPI generation and implementation after technical baseline approval.

Performance Audit Revision Appendix

ส่วนนี้เป็น revision content ที่มีผลเหนือ technical note เดิมเฉพาะเมื่อมีข้อขัดแย้งกัน โดยไม่เปลี่ยน Business Baseline.

9. API Performance Contract Extension

Concern	Technical Contract
List/Search	Tenant/site scope is applied server-side before paging. Query DTO/OpenAPI documents supported filter/sort fields and paging conventions. Server rejects/clamps unbounded page requests according to configured max page size; exact numeric max remains product/deployment configuration until approved.
Cancellation	ASP.NET Core read/report/file paths propagate RequestAborted/CancellationToken to async EF/storage operations where safe. Cancellation must not create partial business state.
Response shape	List endpoints use focused summary DTOs/projections; do not serialize full aggregate graphs for simple list screens.
Report/Export	Functional scope/PII rules are locked. Rows/bytes/time/memory are measured. Streaming vs asynchronous export is selected from observed workload; no new latency or size requirement is invented here.
Files	Authorized API remains the access boundary. Avoid unnecessary full-memory buffering; exact streaming/storage implementation is technical and must preserve <=10MB/type/scan rules.
Caching	No shared/distributed cache is required for MVP. Any later cache requires measured bottleneck, explicit tenant/site isolation, stale-data policy and invalidation design; authorization is never bypassed.

PERF-DEC-01 - Performance Measurement Statistic (Pending Approval).

Business Baseline ระบุ “Normal List/Search <= 3 seconds at 100 concurrent users and 100,000 records per Site” แต่ไม่ได้ระบุว่า 3 seconds หมายถึง Average, Maximum, p95 หรือ p99. จึง **ห้ามถือ p95 เป็น Requirement ที่อนุมัติแล้ว**. Recommendation สำหรับการอนุมัติคือ p95 end-to-end API response time <= 3.0 seconds; ก่อนอนุมัติ ให้บันทึก Average/p50/p95/p99/throughput/error rate ครบและรายงานผลเป็น diagnostic evidence โดยยังไม่ประกาศ Pass/Fail ของ release gate จาก percentile ใด percentile หนึ่ง.

10. API Performance Evidence

Performance runs record endpoint/route Average/p50/p95/p99, throughput, unexpected 5xx/timeouts, correlation/trace samples and DB timing. API performance cannot be declared from average latency alone while PERF-DEC-01 is unresolved.